Monthly Intelligence Dispatch

February 2020

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Several Australian banks received threats from hackers that claimed to be the Russian-speaking APT group **Silence**, which attacks financial organizations worldwide.
- Group-IB discovered a database with over **460,000** payment card records on a darknet card shop. Nearly 98% of the records belonged to major Indian banks' customers.
- **Rambler Group** and **Group-IB** exposed a fraud scheme that purported to be a fictitious award called Like of the Year 2020. In total, more than 1,000 related domains were identified in this campaign.
- During protests in the spring of 2019, two unnamed Hong Kong universities were attacked by the Winnti threat group.
- The UK police arrested individuals suspected in the cyberheist at **Bank of Valetta**, one of Malta's largest banks, in February 2019.

Like of the Year

Rambler Group and **Group-IB** exposed a fraud scheme that purported to be a fictitious award called Like of the Year 2020. In this major phishing attack, users were promised large financial rewards for a randomly chosen like on social media. To attract victims, the fraudsters hacked the mail servers of a fiscal data operator (OFD) and sent out mass messages to users in the Russian-speaking part of the Internet on behalf of the Rambler team. In total, more than 1,000 related domains were identified in this campaign. After users contacted Rambler Group, the company conducted its own investigation and involved Group-IB in responding to the incident. Interestingly, the scammers used multiple attack vectors to trick users into participating in the Like of the Year 2020 award. In addition to sending out emails, they also delivered phishing messages about financial rewards directly to Google Calendar. The recipients were congratulated on winning the contest and on a cash prize that ranged from $100 to $2,000. The use the Gmail service calendar is a relatively recent trend in social engineering. The default calendar settings allow invitation data to be automatically added to the calendar along with a reminder. That way, any Google Calendar user can send event invitations to other Gmail users, even if they are not in their address books. As a result, the victim will receive an email notification about a new event being created. The key words in the content will be “bank, approved, payment of funds, program, reimbursement, receipt, agreed, federal, official, details” and so on. The phishing mailout was eventually stopped and Group-IB specialists managed to block most of the websites related to the attack.

NEC	The Japanese electronics manufacturer **NEC** declared a security breach that took plalce in December 2016. It was only in June 2017 that the intrusion was detected, when the company's employees noticed suspicious outgoing encrypted traffic. The investigation revealed that the attacker exfiltrated **27,445** files from the company's defense business division. NEC has become the second Japanese defense contractor to admit to a security breach. Earlier, Mitsubishi Electric suffered a similar security breach, after hackers exploited a vulnerability in the Trend Micro antivirus. Some believe the Chinese state-sponsored cyberespionage group Tick was behind the NEC attack.
Winnti	During protests in the spring of 2019, two unnamed Hong Kong universities were attacked by the Winnti threat group, experts at ESET reported. The attacks were detected in November 2019: ShadowPad launcher was found on several devices in two universities (interestingly, this happened after previous Winnti infections, which were exposed in October the same year). These were targeted attacks, since the Winnti malware and the modular ShadowPad backdoor contained campaign identifiers and C&C URLs with the names of the affected universities.

VPN

Experts at **ClearSky** say that Iranian APT groups have been trying to target major companies in the IT, telecommunications, oil and gas, and aviation sectors by hacking VPN servers. In 2019, Iranian hacker groups quickly exploited vulnerabilities found in Pulse Secure Connect VPN (CVE-2019-11510), Fortinet FortiOS VPN (CVE-2018-13379), and Palo Alto Networks Global Protect VPN (CVE-2019-1579). The attacks started as early as summer last year — straight after information about the bugs had been published — and continued into 2020. Similarly, attackers promptly took advantage of CVE-2019-19781 found in Citrix ADC VPN.

Miner

Security researcher **Nitesh Surana** detected cryptomining malware on a Jenkins server belonging to the US Department of Defense (DOD). The researcher reported this via the DOD's official bug bounty program. Initially, the bug report was filed in relation to a misconfigured Jenkins automation server running on an Amazon Web Services (AWS) server associated with a DOD domain. Surana warned that anyone could access the Jenkins server without login credentials, meaning the attackers could install a permanent backdoor or take over the entire server. The researcher said he tracked down the clues he found to a malware operation specialized in hacking cloud servers and installing Monero-mining malware. The Monero wallet address that this botnet was using to collect funds started to be mentioned online in August 2018. Most mentions have been from Chinese users, who reported finding a Monero miner on their cloud servers.

Fake Silence

Several Australian banks received threats from hackers who claimed to be the Russian-speaking APT group Silence, which attacks financial organizations worldwide. The threats are known to have been received through emails, which said that if the bank did not pay a ransom in **Monero**, it would be subjected to a DoS attack. Rustam Mirkasymov, a threat intelligence expert and head of Group-IB's Dynamic Malware Analysis team, questioned whether it is Silence that is behind the threats, saying that "such blackmail is not typical of the group." "Even though Silence has expanded its geography and increased the frequency of their attacks, particularly in the Asia-Pacific region, we have not seen their traces in Australia," underscored Mirkasymov. He noted that that was not the first case when threat actors use the names of notorious APTs to blackmail and intimidate their victims. For instance, in October 2019 Group-IB specialists discovered a mailout to financial organizations that purported to be from the Fancy Bear group (APT28); the emails threatened to launch a DDoS attack unless a ransom was paid.

naszBot

On February 4, 2020, a malicious mailout to Russian banks was observed. Infected devices had malware launched, which on command from the C&C server could collect and transfer information about the computer as well as download and launch payload. Group-IB experts classified this malware as naszBot (the application uses Polish words for commands). The C&C server domain registration information featured an email address that had earlier been used to register domains involved in the distribution of TA505.Get2, it was observed. Presently, it has not been possible to definitively say whether naszBot is a new tool of the TA505 group or of a different threat group that might be using the same domain registration service as TA505.

Major events: databases

Joker's Stash	Group-IB discovered a database with over **460,000** payment card records on a darknet card shop. Nearly 98% of the records belong to major Indian banks' customers. The underground market value of the database is estimated at more than **$4.2 million**. Group-IB immediately informed the Indian Computer Emergency Response Team (CERT-In) about the incident, so that they could take necessary measures. This is a second major upload of payment records related to Indian cardholders. On October 28, 2019, Group-IB's Threat Intelligence team discovered a database with over 1.3 million credit and debit card records of mostly Indian banks' customers, also uploaded to Joker's Stash. The underground market value of the database was estimated at more than $130 million.
Dublikat	A database with information of over 1.2 million customers of Russian microfinance institutions (MFIs) was uploaded to **Dublikat**, an underground online forum, by a new forum user. This was reported by Dmitry Shestakov, the head of the Cybercrime Research team at Group-IB. He noted that such databases are highly values by threat actors, as they can use the collected personal information of MFI customers for spam calls or phishing mailouts. "The sale of such databases is not a rarity. For instance, in January 2020 only, two underground services that sell MFI databases were launched," highlighted Shestakov.

0-day	Monitoring of the underground revealed a post on the Exploit.in forum advertising the sale of a zero-day exploit chain for iOS 13. The author of the post is a user called delgado. The exploit chain, which is designed for Apple's latest iOS version, uses a remote code execution (RCE) vulnerability in Safari, an LPE vulnerability and jealbreak. The author noted that they were only an intermediary between buyers and the company that owned the exploit chain. The price is €2 million. Purchasing it requires being personally present at the company's European office.
network	In November 2019, a user named network made their first post about selling remote access to the corporate network of a European company on Exploit.in. The user also made posts about selling access to 40 different companies (banks, travel agencies, clinics, universities, insurers, software manufacturers, etc.) worldwide. The threat actor is selling two types of access: domain admin access (access with administrator rights) and session access (e.g. Cobalt Strike or Armitage session).

Arrests and sentences

Bank of Valletta

The UK police arrested individuals suspected of hacking Bank of Valetta, one of Malta's largest banks, in February 2019. The UK's National Crime Agency arrested two men aged 22 and 17 in London. A third suspect, a 39-year-old man, was arrested in Belfast, Northern Ireland. All three individuals were arrested on suspicion of money laundering and it is not clear yet whether they were the organizers of the heist or helped hackers launder the stolen money.

Ryan Hernandez

Ryan Hernandez, a 21-year-old resident of California also known as RyanRocks, pleaded guilty to hacking the servers of **Nintendo** and stealing thousands of files with confidential and proprietary information. The attack lasted from October 2016 through June 2019. Hernandez and an associate used a phishing technique to steal credentials of a Nintendo employee: a malicious link was posted on the company's official forum requesting help with a technical issue. As a result, a tech support employee was infected with malware. This helped the attackers download a large body of data using stolen credentials. The information they stole included data on equipment, games (including unreleased ones), developer tools, the company's plans, and so on. Hernandez later published a lot of this data on social media platforms, Discord, etc. RyanRocks drew infamy in the Nintendo hacking community for allegedly leaking a Nintendo Software Development Kit that had a piece of hidden Remote Access Tool malware added to it.

Forecasts and warnings

- IT networks will remain the main attack vector for threat actors. Access to these segments is crucial for espionage and collecting information about how to attack a particular energy company for sabotage purposes. OT network compromise will be the next step once the network's IT segment is successfully breached. Detecting OT compromise is only possible in two cases: if the attack is designed for sabotage purposes or if the malware operator makes a mistake. For this reason, attackers often try to be as covert as possible until they must carry out a mass attack.
- Supply chain attacks will pose a serious problem for the energy sector from the part of various software and hardware providers. Management companies will be attacked first, then used to penetrate networks belonging to energy companies. The most significant threat is expected to come from developed countries. Threat actors in such regions are better equipped, which is why their activity is less noticeable and less thoroughly investigated.
- Cybercriminals are increasingly shifting from traditional ways of stealing money from bank accounts to social engineering. Up to 70% of thefts from the bank accounts of Russian banks' customers were carried out involving the account and bank card owners themselves, i.e. using social engineering techniques, estimated at Russia's Central Bank.
- Using the Gmail calendar is a relatively recent social engineering trend. The default calendar settings allow invitation data to be automatically added to the calendar along with a reminder. Disable the automatic addition of invitations and events to your Google calendar (Settings > Events from Gmail > Automatically add events from Gmail to my calendar (uncheck the box)).

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159-3798
+7 495 984 33 64
intelligence@group-ib.com